

SOCIII Security Policy

sociii.ai Platform · Effective August 28, 2026

This document describes the technical and organizational security measures SOCIII, Inc. ("SOCIII") applies to the data it processes on behalf of customers, including institutional and educational customers. It is intended to be read alongside our Privacy Policy and, where applicable, a signed Data Processing Agreement (DPA) or FERPA addendum.

1. Data Storage and Isolation

Customer data is stored in Google Cloud Platform infrastructure (Firestore), logically isolated per tenant — every record is scoped to the customer's own workspace. For customers with stricter isolation requirements, a Dedicated tier is available: a fully separate, region-pinned database with customer-held encryption keys (CMEK) that the customer can revoke independently.

2. Encryption

- Data in transit: TLS 1.2 or higher for all connections to the platform
- Data at rest: AES-256 encryption via the underlying Google Cloud Platform infrastructure
- Payment data: collected and stored exclusively by Stripe; SOCIII never stores raw card numbers

3. Audit Trail and Data Integrity

Actions taken by AI Digital Workers on regulated data are recorded as immutable, append-only events, hash-chained, and periodically anchored to an independent, external ledger outside SOCIII's own infrastructure. This means an internal actor with infrastructure access cannot silently rewrite history without the divergence being independently provable. Records created since the last anchoring interval carry hash-chain protection; the anchor interval itself bounds how current that stronger guarantee is at any moment.

4. Internal Access Controls

- SOCIII staff do not have routine access to customer tenant data.
- Any access is least-privilege, time-boxed, and logged.
- Support access to a customer's data requires an open ticket or the customer's written authorization, plus a second-person internal approval — no single SOCIII employee can self-grant access.
- Access events are themselves written into the same tamper-evident audit trail described in Section 3.
- On the Dedicated tier, customer-held encryption keys (CMEK) mean the customer can revoke SOCIII's ability to decrypt their data entirely.

5. AI Model Providers and Subprocessors

SOCIII routes AI inference to Anthropic, PBC and OpenAI, L.L.C. under enterprise API terms. **No model vendor used by SOCIII trains on customer data.** This is a contractual guarantee, not a policy preference. A current subprocessor list, including region and data category handled by each subprocessor, is available on request and is part of the standard DPA.

6. Retention and Deletion

On request, or upon termination of an agreement, SOCIII will purge a customer's data from primary storage and backups within a defined window (specified in the applicable order form or DPA) and provide confirmation of deletion. Deleting a record does not compromise the integrity of the external audit anchor described in Section 3 — the anchor stores only a hash of the record, never the underlying data, so a deleted record cannot be reconstructed from it.

7. Incident Response and Breach Notification

SOCIII maintains an internal incident response process with defined severity levels. In the event of a confirmed data breach affecting a customer's data, SOCIII will notify the affected customer's designated contact with scope, affected data, and remediation steps, before any public disclosure, and within the timeframe required by applicable law (72 hours under GDPR where applicable).

8. Independent Validation — Stated Honestly

SOCIII is an early-stage vendor. As of this document's effective date, we do not yet hold a completed third-party security attestation (SOC 2 report or independent penetration test on file). This is a near-term roadmap item, not a claim we make today. What is in place today is described in Sections 1–7 above, and we will share progress, and any bridge letter or report, on request as this matures. We would rather state this plainly than imply a level of independent validation that doesn't yet exist.

9. Education-Sector Specifics (FERPA)

Where SOCIII processes student education records on behalf of an educational institution, SOCIII acts as a "school official" with a "legitimate educational interest" under 34 CFR §99.31(a)(1) — meaning SOCIII uses education records only under the institution's direction, only to perform the contracted service, and does not re-disclose them except as authorized. Our AI subprocessors (Section 5) operate under the same direct-control, no-training terms, so AI processing does not constitute uncontrolled re-disclosure. A FERPA addendum accompanies the standard DPA for education customers.

10. Exit and Data Portability

Customer data is portable by design. On request, or at contract termination, SOCIII provides a full export of a customer's data in an open, documented, machine-readable format, readable without SOCIII's own software.

11. Contact

Security questions or to request our current subprocessor list: security@sociii.ai

Privacy questions: privacy@sociii.ai

Postal: SOCIII, Inc., 131 Continental Dr, Suite 305, Newark, DE 19713